

Activitat 4: Apache SSL

Objectiu de la pràctica

Comprensió de l'arquitectura client-servidor.

Conèixer els protocol HTTPS i quins avantatges té respecte HTTP.

Configurar servidor Apache per a HTTPS.

Requeriments

Màquina virtual amb una distribució Linux (Ubuntu 24.04 recomanada).

Un navegador web (google-chrome o firefox preferiblement)

Instal·lar Apache en entorn Linux.

Introducció a la pràctica

Aquesta pràctica està dividida en 2 parts

Punts a tenir en compte sobre HTTPS

1. HTTPS és el resultat d'afegir una capa de software que implementa el protocol SSL/TLS per sota de la capa que implementa el protocol HTTP. Per tant, HTTPS no és un protocol per ell mateix sino la combinació de HTTP sobre SSL/TLS. Tots dos protocols són de nivell d'aplicació.
2. SSL/TLS són protocols criptogràfics que permeten afegir autenticació i privacitat (per mitjà de l'encriptació de dades) a les comunicacions. TLS (Seguretat de Capa de Transport) és l'evolució del protocol SSL (Capa de Connexió Segura).
3. Per mitjà de HTTPS es pot afegir privacitat (o confidencialitat) a les comunicacions entre el client i el servidor web. Per tant, podem establir connexions segures tot i que la xarxa en la qual ens trobem sigui insegura (per exemple, una wifi). Per afegir privacitat s'utilitza un sistema de criptografia de clau simètrica per encriptar les dades entre el client i servidor. La clau simètrica canvia en cada sessió de connexió.
4. Per mitjà de HTTPS es pot afegir autenticació del servidor i també si és necessari, del client. L'autenticació del servidor assegura al client que "el servidor és realment qui diu que és".
5. Per realitzar la autenticació d'un servidor, cal que tingui instal·lat un certificat. Les comunicacions segures per mitjà de SSL/TLS utilitzen certificats norma X.509.

Aquests certificats permeten l'autenticació per mitjà d'un sistema d'encriptació asimètrica coneguda amb el nom de criptografia de clau pública.

6. El servidor i el client s'intercanvien la clau de simètrica que s'utilitza per encriptar la comunicació en cada sessió de connexió per mitjà del sistema de clau pública.
7. El certificat és molt important perquè assegura l'autenticitat de les dues parts de la comunicació, sobretot del servidor (generalment, no cal autenticar al client).
Existeixen dos tipus de certificats:

- a) Certificats autosignats i
- b) Certificats signat per una Autoritat de Certificació (CA).

NOTA: Us heu fixa't que al navegador de vegades apareix https de color verd i d'altres vegades de vermell. Què creieu que vol dir?

8. Un certificat signat per una CA i instal·lat en un servidor, assegura al client que una autoritat externa en la qual es confia (l'autoritat de certificació o CA) confirma que el posseïdor del certificat és realment qui afirma ser. Una CA pot ser una autoritat governamental o una empresa de prestigi reconegut. La Generalitat, el ministeri de l'interior o empreses com Verisign són exemples de CA. Per mitjà d'un certificat signat per una CA podem tenir comunicacions encriptades i ens assurem de l'autenticitat del servidor o també a vegades del client (per exemple, quan paguem impostos per internet). Els certificats signats per una CA s'han de pagar.
9. Un certificat autosignat és un certificat en la qual una entitat es certifica a ella mateixa. Evidentment, si ens connectem a un servidor amb un certificat autosignat no podem assegurar l'autenticitat però com a mínim les dades viatgen encriptades. Els certificats autosignats són de franc (me'ls faig jo mateix).
10. Un certificat autosignat pot ser suficient per una organització petita a on tothom es coneix i l'autenticació no sigui necessària però si que és necessari la privacitat de les comunicacions. Si es vol posar una botiga virtual o es treballa per una organització gran llavors sí que és necessari per proporcionar autenticació i encriptació.
11. Si el client no té un certificat es poden introduir els mecanismes d'autenticació que vam veure a la pràctica anterior per demanar a l'usuari un nom d'usuari i una contrasenya i que s'autentifiqui.
12. És molt recomanable que a mode de síntesi com a suport, mireu el següent vídeo :
<https://www.youtube.com/watch?v=4nGrOpo0Cuc>
13. Per comprovar que el servei HTTPS estigui escoltant pel port 443, en sistemes Linux podeu utilitzar la comanda : `netstat --tcp --listen -p -n`

Enunciat de la pràctica

Part 1 - Configuració del servidor

L'objectiu d'aquesta pràctica és configurar un servidor Apache per tal que utilitzi HTTPS sota una distribució Linux (Xubuntu, Ubuntu, Debian, ...).

1. Partiu d'una de les sites creades. P.ex /var/www/html/daw2. Assegureu-vos que contingui un index.html com aquest:

```
<html>

<title>web segura del lloc www.daw2.net</title>

<body>

<h1>Inici  www.daw2.net</h1>

Aquesta web només és accessible via https <br/>

</body>

</html>
```

2. Instal·la en el teu servidor un certificat i una clau pública:
 - a) Crea un certificat autosignat per al servidor www.daw2.net (FQDN del certificat).
Per fer-ho pots mirar el que diu l'adreça:
[https://www.digitalocean.com/community/tutorials/how-to-create-a-self-signed-s
sl-certificate-for-apache-in-ubuntu-18-04-es](https://www.digitalocean.com/community/tutorials/how-to-create-a-self-signed-ssl-certificate-for-apache-in-ubuntu-18-04-es)
 - b) Has de generar els fitxers daw2.crt i daw2.key
 - c) Copia el fitxer daw2.crt a /etc/ssl/certs. Copia el fitxer daw2.key a /etc/ssl/private.
3. Crea l'arxiu de configuració d'un lloc virtual www.daw2.net: La seva configuració ha de trobar-se al fitxer /etc/apache2/sites-available/daw2.conf . Utilitza com a model per crear-lo el fitxer /etc/apache2/sites-available/default-ssl. Els recursos del lloc virtual es trobaran a la carpeta /var/www/html/daw2.

NOTA: Com a recurs per fer l'exercici 3 , et suggereixo que consultis les següents webs :

[https://www.digitalocean.com/community/tutorials/como-configurar-virtual-h
ost-de-apache-en-ubuntu-14-04-lts-es](https://www.digitalocean.com/community/tutorials/como-configurar-virtual-host-de-apache-en-ubuntu-14-04-lts-es)

<http://www.maestrosdelweb.com/host/>

- a) Assegurar-se que la directiva SSLEngine és igual a on.
- b) Modificar la directiva SSLCertificateFile perquè apunti al certificat daw2.crt.
- c) Modificar la directiva SSLCertificateKeyFile perquè apunti a la clau daw2.key

Les directives més importants a modificar són:

- d) Afegir la directiva ServerName per indicar el nom del lloc virtual (www.daw2.net).
 - e) Modificar la directiva DocumentRoot per indicar el directori a on es desen els recursos del lloc virtual.
 - f) Modificar la directiva Directory tal per indicar els permisos del directori a on es desen els recursos del lloc virtual.
4. Activa el mòdul SSL del servidor Apache. Executa: `a2enmod ssl`. ... i comprova que s'ha activat amb l'ordre: `apachectl -M`
- NOTA:** El nom del mòdul un cop activat és `ssl_module`
5. Comprova que el servidor Apache ara també escolta pel port 443/tcp. (per exemple, pots utilitzar la comanda `netstat`)
6. Activa el lloc virtual `www.daw2.net` amb l'ordre: `a2ensite daw2`

Part 2 - Configuració del client

- 1. Comprova l'adreça IP del servidor.
- 2. Modifica el fitxer `/etc/hosts` (Linux) i afegeix una nova línia a on surti l'adreça IP del servidor i el nom del lloc virtual.
- 3. Des del navegador, estableix una connexió segura amb el servidor, establint una connexió a la URL:

<https://www.daw2.net>
- 4. En el moment de connectar-te, confirma l'excepció de seguretat i aconsegueix el certificat. Visualitza el certificat. Finalment, comprova que pots accedir a la web del lloc virtual.
- 5. Comprova que has carregat el certificat en el teu navegador. Des de Firefox, ves a Edita → Preferències → Privacitat i seguretat → Certificats → Visualitza els certificats, i troba el certificat daw2.crt.
- 6. Tanca el navegador i torna a connectar-te al lloc virtual. Comprova que ara has entrat directament perquè el certificat està carregat.

NOTA: Compte amb els paràmetres de configuració de l'històric del navegador. Si s'esborra tot cada vegada que atures el navegador llavors cada vegada que posis en marxa el navegador, et torna a demanar l'entrada de l'excepció de seguretat.

Comprovació de que tot funciona per passos:

- a) Servidor escoltant pel port 443
- b) Comprovació de l'adreça IP del servidor.
- c) Comprovació del fitxer hosts del client.
- d) Connexió segura <https://www.daw2.net>
- e) Comprovació del certificat de seguretat descarregat en el client.